LAB 02 — BRUTE FORCE ATTACK

Detection & Analysis Using Windows Event Logs

By Saravanan | github.com/Saravanan-Patrick | March 2026

This is a fully isolated, controlled lab environment. No real systems were targeted. All simulations performed on personal VMs for educational purposes only.

About This Lab

Lab 02 builds on the network reconnaissance performed in Lab 01 by simulating a real-world brute force attack against a Windows 10 target. Using Metasploit's smb_login module from Kali Linux, the attack attempts multiple passwords against the Administrator account via SMB port 445 — the same port discovered in Lab 01. The Windows 10 VM generates failed login events (Event ID 4625) which are then analyzed as a SOC analyst would.

This is exactly what a Tier 1 SOC analyst does every day — detect brute force patterns in Windows Event Logs and investigate the source.

Lab Environment

Component	Details
Hypervisor	VMware Workstation Pro 25H2
Attacker Machine	Kali Linux 2025.4 (amd64)
Defender/Target	Windows 10 x64
Network Type	VMware LAN Segment — Isolated (testpractice)
Attacker IP	192.168.20.11 (Static)
Target IP	192.168.20.10 (Static)
Internet Access	None — Fully Air-Gapped Lab

Attack Tool	Metasploit Framework v6.4.99 — smb_login module
Detection Method	Windows Event Viewer — Event ID 4625
Target Port	445/TCP — SMB (Server Message Block)

Attack Simulation — Attacker Side (Kali Linux)

Step 1 — Create Password Wordlist

A custom password wordlist was created on the Kali Desktop containing 8 commonly used passwords:

```
cd ~/Desktop
nano passwords.txt
```

Passwords included in the wordlist:

- password
- 123456
- admin
- welcome
- Password123
- letmein
- qwerty
- administrator

Step 2 — Launch Metasploit Framework

Metasploit was launched from the Kali terminal:

```
msfconsole
```

Metasploit Framework v6.4.99-dev loaded with 2,572 exploits and 1,317 auxiliary modules.

Step 3 — Configure SMB Login Scanner

The smb_login auxiliary module was selected and configured to target the Windows 10 VM:

```
use auxiliary/scanner/smb/smb_login
set RHOSTS 192.168.20.10
set SMBUser administrator
set PASS_FILE /home/kali/Desktop/passwords.txt
run
```

Step 4 — Attack Execution Results

Metasploit attempted all 8 passwords from the wordlist against the Administrator account via SMB port 445:

Attempt #	Password Tried	Result	Event Generated

1	password	Failed — Incorrect password	Event ID 4625
2	123456	Failed — Incorrect password	Event ID 4625
3	admin	Failed — Incorrect password	Event ID 4625
4	welcome	Failed — Incorrect password	Event ID 4625
5	Password123	Failed — Incorrect password	Event ID 4625
6	letmein	Failed — Incorrect password	Event ID 4625
7	qwerty	Failed — Incorrect password	Event ID 4625
8	administrator	Failed — Incorrect password	Event ID 4625

Detection — Defender Side (Windows Event Viewer)

Windows Event ID Reference

Event ID	Event Name	Meaning	SOC Significance
4625	Failed Logon	Someone attempted to login and failed	CRITICAL — brute force indicator
4624	Successful Logon	Someone logged in successfully	Check if follows multiple 4625s
4648	Logon with explicit creds	Credentials used explicitly	Lateral movement indicator
4720	User account created	New account created on system	Possible backdoor creation
4732	Added to admin group	User added to Administrators group	Privilege escalation alert

Event ID 4625 Analysis

After filtering Windows Security logs for Event ID 4625, the following was observed:

Field	Value	What It Tells Us
Total Failed Logins	10 events	High frequency = brute force pattern
Account Targeted	Administrator	High-value account — attacker knew target
Source IP Address	192.168.20.11	Kali Linux attacker machine
Source Port	445/TCP (SMB)	Attack via file sharing protocol
Failure Reason	Unknown username or bad password	Password guessing confirmed
Logon Type	3 (Network Logon)	Remote authentication attempt
Time Window	Within 2 minutes	Automated tool — not manual typing
Workstation Name	KALI	Attacker hostname visible in logs

Brute Force Detection Rule

In a real SOC environment, a SIEM rule would automatically detect this pattern:

> SIEM Alert Rule: IF (Event ID 4625 count > 5 from same Source IP within 60 seconds) THEN trigger BRUTE FORCE ALERT → assign to Tier 1 analyst for investigation

Splunk query to detect this attack:

```
index=wineventlog EventCode=4625
| stats count by src_ip, user
| where count > 5
| sort -count
```

Indicators of Compromise (IOCs)

IOC Type	Value	Significance
Source IP	192.168.20.11	Kali Linux — attacker machine
Target IP	192.168.20.10	Windows 10 — victim machine
Target Account	Administrator	High privilege account targeted
Attack Protocol	SMB — Port 445/TCP	Same port from Lab 01 Nmap scan
Attack Tool	Metasploit smb_login v6.4	Identified from network traffic
Event ID	4625 — Failed Logon	10 events in under 2 minutes
Logon Type	3 (Network)	Remote authentication attempt
Date/Time	2026-03-15 at 19:14	Attack timestamp
Failure Count	10 failed attempts	Exceeds normal threshold of 3-5

Security Observations

1. SMB Port 445 is a High-Value Attack Target

This is the SAME port discovered open in Lab 01 Nmap scan. An attacker's workflow is: 1) Reconnaissance (Nmap — Lab 01) → 2) Attack (Brute Force via SMB — Lab 02). This demonstrates exactly how the Cyber Kill Chain works in real attacks.

2. Administrator Account Should Be Renamed or Disabled

The attacker immediately targeted 'Administrator' because it is the default Windows admin account. In production environments this account should be renamed or disabled and replaced with a named admin account. This is a basic security hardening step.

3. Account Lockout Policy Was Not Configured

The attack was able to attempt all 8 passwords without the account being locked. In a hardened system, Account Lockout Policy should be set to lock the account after 3-5 failed attempts. This would have stopped the attack at attempt 4.

4. No MFA on SMB Authentication

Multi-Factor Authentication would have completely prevented this attack even if the correct password was guessed. Modern enterprise environments enforce MFA for all remote authentication.

5. Attack Was Fully Visible in Logs

The positive finding here is that Windows Event Logging captured every single failed attempt with full details including source IP, timestamp, account name, and logon type. A SIEM monitoring these logs would have triggered an alert within seconds.

What I Learned

- How brute force attacks work in practice — automated password guessing via Metasploit
- How to use Metasploit's smb_login module for credential attacks
- How Windows generates Event ID 4625 for every failed login attempt
- How to filter Event Viewer by specific Event IDs to find security events
- How to identify brute force patterns from log analysis — frequency + source IP
- The importance of Account Lockout Policy in preventing brute force attacks
- How Lab 01 (Nmap) and Lab 02 (Brute Force) connect — recon leads to targeted attack
- How SOC analysts use SIEM queries to detect brute force patterns automatically
- The Cyber Kill Chain in action across two labs — Reconnaissance → Exploitation

Repository Structure

```
Lab-02-Brute-Force-Detection/
├── README.md
├── metasploit-bruteforce-results.txt
└── screenshots/
    ├── metasploit-smb-login-setup.png
    ├── metasploit-attack-running.png
    ├── event-viewer-4625-filter.png
    ├── event-id-4625-details.png
    └── event-id-4625-total-count.png
```

Interview Answers — Use These!

> **Q: How would you detect a brute force attack?**
>
> *A: I would look for multiple Event ID 4625 (failed login) events from the same source IP in a short time window. In my home lab, I simulated this using Metasploit smb_login module from Kali Linux against*

Windows 10. It generated 10 failed login events in under 2 minutes all from 192.168.20.11. In a real SIEM I would write a rule: if Event ID 4625 count exceeds 5 from same IP within 60 seconds, trigger a brute force alert.

Q: What is Event ID 4625?

A: Event ID 4625 is the Windows Security event generated every time a login attempt fails. It contains critical details — the account targeted, source IP address, logon type, and failure reason. In my lab I found 10 of these events generated by a Metasploit brute force attack all originating from 192.168.20.11, confirming the attacker IP and attack pattern.

Q: How do Lab 01 and Lab 02 connect in a real attack scenario?

A: They represent two stages of the Cyber Kill Chain. Lab 01 was Reconnaissance — using Nmap to scan the target and discover open ports including 445 SMB. Lab 02 was Exploitation — using that knowledge to launch a targeted brute force attack via the same SMB port. This is exactly how real attackers operate: scan first, then attack what you find.

About Me

Saravanan — transitioning from Food Technology into Cybersecurity with a focus on SOC Analysis and Blue Team operations. This lab is part of my Mini SOC Home Lab series documenting hands-on learning.

Contact	Details
GitHub	github.com/Saravanan-Patrick
LinkedIn	linkedin.com/in/saravanan-cyber
Email	career.entrydesk@gmail.com
Location	Thiruvallur, Tamil Nadu, India

"Every attack leaves a trace. A good SOC analyst finds it."

⋆ If this lab helped you, give the repo a star!